confidential because anyone might be in possession of the public key. However, it could be used if it was important to verify who the sender was. Only the sender has the private key and the public key only works with that one specific private key. Therefore, if the recipient finds that the decryption is successful, the message has in effect been received with a digital signature identifying the sender.

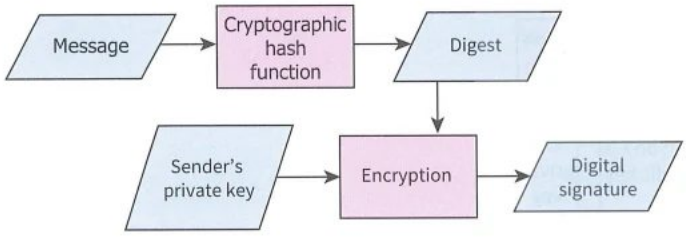


Figure 21.02 Sender using a one-way hash function to send a digital signature

There is a disadvantage in using this method of applying a digital signature: it is associated with an encryption of the whole of a message. An alternative is for the sender to use a public cryptographic one-way hash function which creates a number that is uniquely defined for the particular message, called a 'digest'. The process at the sender's end of the transmission is outlined in Figure 21.02. The private key is used to encrypt the digest. The encrypted digest is the digital signature. The message can be transmitted as plaintext together with the encrypted digest as a separate file. Because the digest is much smaller than the whole message the encryption and the transmission are faster processes than if the whole message were encrypted.

The processes that take place at the receiver end are outlined in Figure 21.03. The same public one-way hash function is used to create a digest from the received message. Then the encrypted version of the original digest is decrypted using the public key.

If the two digests are identical the receiver can be confident that the message is authentic and has been transmitted unaltered.

Note that the digital signature is different each time this process is used. This is because the digest is uniquely defined by the hash function being applied to that particular message.

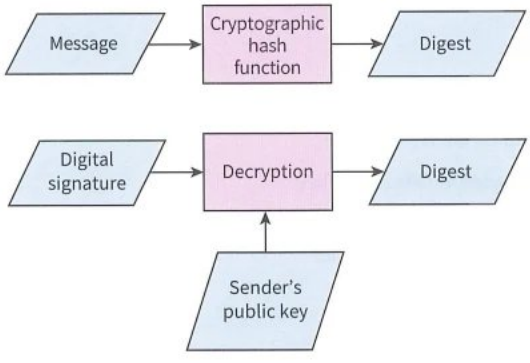


Figure 21.03 Receiver checking that the received transmission is authentic and unchanged

However, the authenticity only confirms to the receiver that the message was sent from the person who had sent them the public key. It does not consider the fact that someone might create a public key and pretend to be someone else.

Therefore, a more strict way of ensuring authentication is needed. This can be provided by a Certification Authority (CA) as part of a Public Key Infrastructure (PKI).

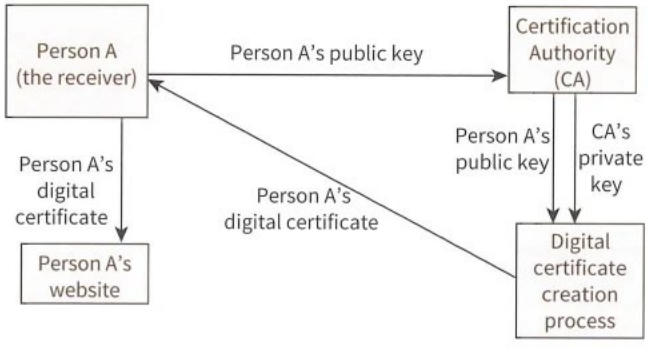


Figure 21.04 Processes involved in obtaining a digital certificate

Let's consider a would-be receiver who has a public–private key pair. The receiver wants to be able to receive secure messages from other individuals, and these individuals want to be confident about the identity of the receiver. The public key must be made available in a way that ensures authentication. The steps taken by the would-be receiver to obtain a digital certificate to allow safe public key delivery are illustrated in Figure 21.04. The process can be summarised as follows.

1. An individual (person A) who is a would-be receiver and has a public–private key pair contacts a local CA.
2. The CA confirms the identity of person A.
3. Person A's public key is given to the CA.
4. The CA creates a public-key certificate (a digital certificate) and writes person A's public key into this document.
5. The CA uses encryption with the CA's private key to add a digital signature to this document.
6. The digital certificate is given to person A.
7. Person A posts the digital certificate on a website.

Figure 21.04 shows person A placing the digital certificate on that person's website but another option is to post it on a website designed specifically for keeping digital certificate data.

Anyone who wishes to extract the public key from the certificate has to use the CA's public key.

For this overall process to work there is a need for standards to be defined regarding the public key infrastructure and the production of the digital certificate. As ever, the name for the standard, X.509, is not very memorable.

TIP

There are two similar processes that have been discussed. In one case someone with a private key sends a public key to someone else. In another case the CA sends a digital certificate containing a public key. Try not to confuse these two.

The following are a few notes to summarise the options available.

- The starting position is someone who has a public–private key pair which are associated with a specific asymmetric key encryption algorithm.
- This person could just make the public key available to anyone who is going to be either a sender or a receiver.
- For optimum security the person instead sends the public key to a Certification Authority.
- The Certification Authority creates a digital certificate which contains the public key with proof of the ownership of the public key.
- Anyone wishing to use the public key obtains it from this digital certificate.
- A message encrypted with the public key could be sent to the owner of the private key.
- A message encrypted with the private key could be sent to anyone having the public key.
- The owner of the private key could use it to create a digital signature that could be used to authenticate an email as was suggested in Chapter 9 (Section 9.03).

21.03 Symmetric key encryption methods

For many years the Data Encryption Standard (DES) was the normal choice for symmetric key encryption. As the weakness of DES became a problem, Triple DES took its place. In 2001 the Advanced Encryption Standard (AES) was introduced as a superior approach. For education purposes only a simplified DES (S-DES) was introduced which allowed the sort of operations performed in encryption to be better understood. The following is an overview of S-DES.

S-DES is an example of a block cipher which means encrypting blocks of bits. In S-DES 8-bit blocks are encrypted. A 10-bit key is chosen. The first stage is to create two 8-bit keys from the 10-bit key. The first step in this first stage is a permutation (reordering of digits) which can be illustrated by the following.

Suppose that the 10-bit key is chosen to be	0101010101
when subjected to a permutation which can be represented by	3 5 2 7 4 10 1 9 8 6
it becomes	0010110011

The numbering of the bit positions is read from left to right so the new 10-bit version has the old position 3 value followed by the old position 5 value and so on. The next step is to apply a circular left shift to the first 5 bits and to the last 5 bits. This produces 0101000111. Finally, the first of the two 8-bit keys to be used in the encryption is created using the permutation 6 3 7 4 8 5 10 9. In our example this key is 00011011. A slightly modified version of this is used to create a second 8-bit key.

The second stage is the encryption, which is a five step process.

1. An initial permutation.
2. Application of a function using the permuted code and the first encryption key.
3. A switch of the first and last 4-bit parts.
4. A repeat application of the function but this time with the second encryption key.
5. A final permutation using the reverse of the initial permutation sequence.

The decryption by the receiver of a transmission uses the same generated 8-bit keys and follows the reverse of the above process.

The AES standard defines the block length as 128 bits. The user can choose to use 128, 192 or 256 bits for the key. The chances of the key being identified from the transmitted ciphertext are small. The main concern is the safety of the method used to provide the key to both sender and receiver.

Extended Question 21.01

Would you like to investigate S-DES further? You could attempt an encryption and decryption.

21.04 Public key encryption methods

RSA (Rivest-Shamir-Adleman), the usual method for public key encryption, is named after the three people who created it. The major features of the method are the key generation algorithm and the encryption function.

The key generation can be summarised as follows.

1. Two very large prime numbers p and q are chosen and their product n is calculated.
2. The product (p-1)(q-1) is calculated.
3. A prime number e less than (p-1)(q-1) and not a factor of it is chosen (65537 is the usual choice).
4. Another number d is found which satisfies the condition that the product of d times e when divided by (p-1)(q-1) gives a remainder of 1.
5. The public key becomes the pair (n,e).
6. The private key becomes the pair (n,d).

The security of the algorithm depends on the fact that finding factors of a very large number is not feasible within any reasonable time scale. Computing n from p and q is straightforward but deducing p and q given n is not!

The encryption works on numbers so a text to be encrypted must first have the characters replaced by numbers according to a sensible coding scheme. If such a number x is to be encrypted as y then y is calculated so that the following relationship holds:

$$y = x^e \bmod n$$

A similar relationship involving d rather than e is used for decryption.

Public key encryption is inherently more secure than symmetric key encryption but the algorithms are not as fast. It is quite common for public key encryption to be used to deliver securely a key that can then be used for symmetric key encryption.

21.05 SSL and TLS

When we access a website, we have two concerns. The first is whether or not the website is genuine. The second is whether we can transfer sensitive personal data to the website, for example to buy a product offered for sale on the website. The Secure Socket Layer (SSL) protocol was created to give assurance to a website user when a client–server application is underway. As described in Chapter 17 (Section 17.04), the interface between an application and TCP uses a port number. In the absence of a security protocol, TCP services an application using the port number. The combination of an IP address and a port number is called a 'socket'. When the Secure Socket Layer protocol is implemented it functions as an additional layer between TCP in the transport layer and the application layer. When the SSL protocol is in place, the application protocol HTTP becomes HTTPS.

The following are some facts concerning SSL.

- Although SSL is referred to as a protocol, it is in fact a protocol suite.
- There is a Record Protocol that deals with the format for data transmission.
- There is also a Handshake Protocol responsible for security.
- The operation of SSL happens without any action from the user.
- The starting point for SSL implementation is a connection between the client and the server being established by TCP.
- The client browser then invokes the Handshake Protocol from the SSP suite.
- The Handshake Protocol requests from the server its SSL certificate which is a digital certificate confirming its identity.
- The server sends this SSL certificate plus its public key.
- The browser uses this public key to encrypt a key which is to be used as a one-off session key for symmetric key encryption to be used for the data transfer during the session.
- There may also be a need at this time to agree which encryption algorithms are to be used.

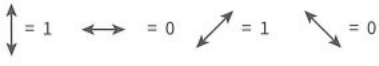
SSL was originally a proprietary protocol. However, it was taken over by the Internet Engineering Task Force (IETF) in order for a standardised version to be produced. This progressed to version 3.0. When the IETF realised that an improved version was required it decided that a new name was appropriate. Transport Layer Security (TLS) is an upgraded version of SSL recommended for use because of some security concerns with the use of SSL. Despite this SSL is still in general use.

Discussion Point:

The use of encryption has always been a controversial subject. There are two important aspects to this. The first is whether powerful, unbreakable encryption algorithms should be made available to the public. The second relates to the key escrow scheme, which allows governments access to all secret keys. You might wish to consider how the content here has relevance to some of the topics in Chapter 9 and Chapter 10.

21.06 Quantum cryptography

Quantum mechanics provides fundamental laws of physics applicable to the behaviour of particles. The particles that transmit light are called photons. Photons demonstrate wave behaviour, so that each photon appears to vibrate in a particular direction at right angles to its direction of travel. The direction each photon vibrates in is called its polarisation, and is represented in a diagram as a double-ended arrow. A photon can be created with a specific polarisation to represent a value for a bit. If we allow four possibilities for the state of polarisation there are two ways to represent a 1 and two ways to represent a 0. This can be illustrated as follows:



This scheme can be used to enable a sender and receiver to create a 'shared secret' code consisting of a number of bits. Table 21.01 illustrates the process.

Bit values sent	1	0	1	1	0	0	0	1	0	1
Polarisation basis	+	×	×	+	+	×	×	+	×	+
Polarisation chosen by receiver	×	+	+	+	×	×	+	×	×	+
Bit values confirmed				1		0			0	1

Table 21.01 Creation of a 'shared secret' code

In Table 21.01 the first row indicates the bit sent, the second row shows the basis used for this with + representing the one using vertical and horizontal and x representing the diagonal pair. The sender chooses the bit pattern at random and also the polarisation basis for each value at random. The third row shows the receiver's choice for the polarisation basis for each value. Again this is a random choice. Following the transmission the sender informs the receiver about the polarisation basis used for each value. The receiver responds by saying which ones were chosen to match. For these matches there is now a stored value for a bit. In the example shown a 'shared secret' code 1001 has been created.

The above scheme has been incorporated in Quantum Key Distribution (QKD) systems. Earlier in this chapter it was mentioned how a key might be transferred using asymmetric key encryption for subsequent use in symmetric key encryption. QKD offers an alternative for the key transfer. The key is still to be used in the normal way. The advantage of QKD is that the transfer does not involve defined values just photons. Anyone trying to intercept the flow of photons in an attempt to discover their polarisation will by the laws of quantum mechanics destroy the photons. A photon cannot be detected and measured then sent on again. The main drawback of quantum cryptography is that it cannot be implemented using standard communication media. It requires a dedicated, special purpose 'quantum channel' between sender and receiver. The costs of providing this are very high so routine use is unlikely.

There are ambitious hopes for the future of quantum computing but progress is slow. QKD is one of the few examples where there has been significant success evidenced.

TASK 21.01

The concept of a 'shared secret' has been used in traditional encryption schemes. An example is the Diffie–Hellman key agreement method. Investigate the principles behind how this works.

Reflection Point:

Chapter 21: Security has some difficult concepts. Have you made sure that you understand the overriding principles and definitions used?

Summary

- Encryption converts plaintext to ciphertext; decryption reverses the process.
- The five main security concerns when transmitting messages are: confidentiality, authenticity, integrity, non-repudiation and availability.
- Alternatives for encryption are symmetric, using one key, or asymmetric, using two different keys.
- Authentication can be achieved using a digital signature and a digital certificate.
- A digital certificate is provided by a certification authority within a public key infrastructure.
- DES and AES are examples of symmetric key encryption.
- RAS is an important asymmetric key method.
- Secure Socket Layer (SSL) which became Transport Layer Security (TLS) provides security when accessing a website.
- Quantum Key Distribution systems use polarised photons.

Exam-style Questions

1 **a** When transmitting data across a network three concerns relate to: confidentiality, authenticity and integrity.

Explain each of these terms. [4]

b Encryption and decryption can be carried out using a symmetric or an asymmetric key method.

Explain how keys are used in each of these methods. You are not required to describe the algorithms used. Your account must include reference to a public key, a private key and a secret key. [6]

c Digital signatures and digital certificates are used in message transmission.

Give an explanation of their use. [5]

2 Secure socket layer (SSL) and its upgraded version named Transport Layer Security (TLS) is described as a protocol suite.

a Explain the meaning of the description 'protocol suite'. [3]

b Describe the type of activity where SSL or TLS would be used. [4]

c Explain how digital certificates are used in the protocol suite. [3]

d Explain how encryption keys are used in the protocol suite. [5]

3 Digital certificates are used in Internet communications. A Certificate Authority (CA) is responsible for issuing digital certificates.

a Name **three** data items present in a digital certificate. [3]

b The method of issuing a digital certificate is as follows.

i A user starts an application for a digital certificate using their computer. On this computer a key pair is generated. This key pair consists of a public key and an associated private key.

ii The user submits the application to the CA. The generated ..... (i) ..... key and other application data are sent. The key and data are encrypted using the CA's ..... (ii) ..... key.

iii The CA creates a digital document containing all necessary data items and signs it using the CA's ..... (iii) ..... key.